CMAWSE Evidence Registry Phase 3.6: 语义与数值完整性审计报告 (SEMANTIC / NUMERICAL INTEGRITY AUDIT)

一、Duplicate SampleUnit ID Attack 取证

1. 当前 Validator 是否拒绝重复 sample_unit_id?
   – 否。models.py 将 sample_unit_ids 定义为 List[str]，未配置 @field_validator 检查列表唯一性（无 len(v) == len(set(v)) 约束）。
2. 如果 denominator == len(set(sample_unit_ids)) 是否可能错误通过?
   – 是。若实现采用去重后的集合长度比对分母（len(set(sample_unit_ids)) == denominator），则输入
   sample_unit_ids = ["SU-01", "SU-01"] 配合 denominator = 1
   将被放行通过；反之，若实现仅做直接列表长度比对（len(sample_unit_ids) == denominator），则
   denominator = 2 会被放行。由于未对列表自身施加无重复约束，攻击者可以通过构造重复 ID
   绕过“独立样本单元数”与“分母”的真值对应。
3. EvidenceGranularity=UNIT_LEVEL 时是否存在同样问题?
   – 否。UNIT_LEVEL 显式断言 len(sample_unit_ids) == 1，天然免疫多项重复注入。
4. AGGREGATE 时是否存在同样问题?
   – 是。AGGREGATE 仅断言 len >= 1 及分母一致性，存在重复 ID 伪造样本容量的漏洞。

DUPLICATE_SAMPLE_ID: BYPASS_POSSIBLE

– 证据定位：src/cmawse/registry/validator.py 中 _check_granularity_and_denominator()
仅执行基数比对，缺失 set(ids) 与原始 ids
等长性断言；tests/test_registry_adversarial_fixtures.py
仅覆盖了显式声明不一致的情况，未覆盖重复 ID 伪装等长场景。

二、Statistic Value Forgery 取证

– 测试行为：构建包含完全合法引用关系、合法枚举、合法物理上游，但 StatisticalRecord.value 从 0.52 被任意篡改为 0.91
的记录。
– Validator 实际反应：
  – Validator 仅执行 Pydantic 字段类型检查（float）与上游 input_evidence_ids 的外键存在性校验；
  – Validator 完全不包含任何统计学重算逻辑（不调用任何置换检验算子、不计算二项/正态/卡方分布），对篡改后的浮点数值无条件接受（B + C
  + D）。

STATISTIC_RECOMPUTATION: ABSENT

三、p-value / CI Forgery 取证

在保持 operator、input_evidence_ids、value 不变的前提下，直接将 p_value 从 0.859 篡改为 0.001，将
ci_95 随意缩放：

- VALUE_INTEGRITY：NOT_ENFORCED（不校验数值是否源自输入 Evidence）
- P_VALUE_INTEGRITY：NOT_ENFORCED（不重算显著性，仅检查 0.0 <= p <= 1.0）
- CI_INTEGRITY：NOT_ENFORCED（不重算置信区间，仅检查 len(ci_95) == 2 且 ci[0] <= ci[1]）

四、Artifact Payload Integrity 取证

检查 EvidenceRecord.artifact_ref：

1. 实际存在性检查：未执行（纯字符串引用，无文件系统 os.path.exists 探针）。
2. 目标指向检查：未执行。
3. 内容完整性检查：未执行。
4. SHA-256 / 密码学哈希对账：未执行（Schema v0.1 的 EvidenceRecord 规范本身未定义 hash 字段）。

PAYLOAD_INTEGRITY: NOT_ENFORCED

五、Claim Semantic Integrity 取证

构造合法统计记录支撑一条严重泛化、范围无限扩大的主张（如由局部单变量不显著推演“证明所有大模型均无因果能力”）：

- Validator 行为表现：
  - Validator 仅检查 ClaimRecord.claim_type 是否在 Schema v0.1 的 4 个枚举内；
  - 检查 supporting_evidence_ids / supporting_statistic_ids 是否存在；
  - 完全不解析 ClaimRecord.statement 的自然语言语义，无法阻止任何范围通胀、因果泛化或模型过度外推。

CLAIM_SEMANTIC_INTEGRITY: STRUCTURAL_ONLY

六、Downstream Claim Back-Reference Attack 取证

- 检查事实：
  - Validator 的拓扑检查仅断言“有向无环（DAG）”与“被引用 ID 存在”；
  - 如果攻击者预先写定虚假结论 Claim，随后伪造一条数据格式完美闭合但纯属捏造的 StatisticalRecord，并将其挂接至合法的
    EvidenceRecord，整个链条将被 Validator 判定为完全合规。
  - Validator 仅能防范循环死锁与断裂悬挂，无法验证推导过程的认识论正当性。

七、最终分类汇总

ATTACK_01_DUPLICATE_SAMPLE_ID: BYPASS_POSSIBLE
ATTACK_02_STATISTIC_VALUE_FORGERY: BYPASS_POSSIBLE
ATTACK_03_P_VALUE_FORGERY: BYPASS_POSSIBLE
ATTACK_04_CI_FORGERY: BYPASS_POSSIBLE
ATTACK_05_ARTIFACT_PAYLOAD_FORGERY: OUT_OF_SCOPE
ATTACK_06_SCOPE_EXPANSION: BYPASS_POSSIBLE
ATTACK_07_DOWNSTREAM_CLAIM_BACKREFERENCE: BYPASS_POSSIBLE

CURRENT_VALIDATOR_SECURITY_LEVEL: STRUCTURAL_PLUS_PROVENANCE

(说明：当前系统实现了“数据结构类型约束 + 有向引用溯源图完整性”，但不具备数值重算、载荷指纹比对与语义真值鉴别能力。)

八、核心问题裁决

问：“当前 Evidence Registry Validator 究竟是在验证 A（Registry 结构是否合法）还是 B（Registry
中记录的科学事实本身是否真实）？”

答：严格且仅在验证 A（Registry 结构是否合法）。

法医级界限声明：

\text{STRUCTURAL VALIDATION} \neq \text{NUMERICAL RECOMPUTATION} \neq \text{SOURCE PAYLOAD VERIFICATION} \neq \text{SCIENTIFIC TRUTH VALIDATION}

1. 结构合法 (Structural Validity)：代表 JSON/对象符合 Schema 契约，没有野指针、悬挂引用和环状拓扑。当前
   Validator 100% 具备此项能力。
2. 数值真实 (Numerical Truth)：需要独立统计求解器根据原始数据点重跑 Wilcoxon / Bootstrap / Fisher
   精确检验。当前系统不具备该能力。
3. 载荷真实 (Payload Authenticity)：需要外部文件系统的不可变 SHA-256 哈希链签核。当前系统不具备该能力。
4. 科学事实真理性 (Scientific Truth)：需要排除过度概括、控制混淆变量与实验范式有效性，属于人类同行评审与高级因果论证范畴。任何自动化
   Registry Validator 均绝不可能仅凭结构校验替代科学事实真理性证明。